

DATA PROCESSING AGREEMENT / AUFTRAGSVERARBEITUNGSVERTRAG

Data Processing Agreement

GDPR Pilot Documentation Package — Research Data Access

— THE PARTIES

- (1) **Controller / Data Controller:** Maria Polychroniadou, PhD Candidate and Founder, HealthLedgerAI — conducting doctoral research on AI-assisted billing compliance in private healthcare in Cyprus and Greece. Contact: info@healthledgerai.com (hereinafter "**the Controller**").
- (2) **Processor / Data Processor:** _____ (Hospital name — full legal name and registered address to be completed by the hospital representative before signing) (hereinafter "**the Hospital**" or "**the Processor**").

This Data Processing Agreement (the "**Agreement**") is entered into between the Controller and the Processor as of the date last signed below (the "**Effective Date**"). The parties agree that personal data shall be processed strictly under the terms set out herein, and exclusively for the purpose of enabling the Controller to conduct a research validation pilot of the HealthLedgerAI billing-compliance prototype on the Hospital's operational billing records.

1. Purpose and Scope of Processing

The Hospital grants the Controller temporary, read-only access to a pseudonymised extract of its billing records for the sole purpose of validating and evaluating the HealthLedgerAI prototype as part of the Controller's doctoral research programme. Specifically:

- Purpose: PhD research validation — testing the accuracy of the HealthLedgerAI AI-assisted billing-compliance detection system against real hospital billing data;
- Strictly no commercial use of any data, records, or outputs derived therefrom;
- The pilot forms part of the Controller's doctoral research record and supports evidence submitted for the European Innovation Council (EIC) Pre-Accelerator programme;
- No data shall be published, monetised, or shared with any third party beyond what the EIC application process and doctoral examination strictly require, and only in fully anonymised, aggregate form.

2. Legal Basis for Processing

The processing of personal data under this Agreement is grounded on the following legal bases under Regulation (EU) 2016/679 (GDPR):

- **Art. 6(1)(f) Legitimate interest** — the Controller's legitimate interest in conducting academic research into billing compliance in private healthcare, balanced against the data subjects' rights by the pseudonymisation and strict access controls applied;
- **Art. 9(3) Health data — academic research exemption** — processing of special category data (health-related billing records) is permitted where it is necessary for scientific research purposes under Union or Member State law and subject to appropriate safeguards;

- Any applicable national research exemptions under Greek Law 4624/2019 and the Cyprus Commissioner for Personal Data Protection Act Cap. 138.

3. Duration and Data Deletion

This Agreement is effective from the Effective Date and continues for the duration of the pilot visit only. The Controller undertakes to:

- Delete all data received from the Hospital within **thirty (30) days** of the conclusion of the pilot visit;
- Certify in writing to the Hospital upon deletion;
- Retain no copies, extracts, or derivatives of the Hospital's data beyond the above period, except as required by law or for the doctoral examination record in fully anonymised form.

4. Sub-Processors

The Controller shall engage **no sub-processors** in connection with this Agreement. All data shall be processed locally on the Controller's device only and shall **never be uploaded to any external server, cloud platform, or third-party service**. No internet transfer of Hospital data shall take place under any circumstances.

5. Data Subject Rights

The Hospital retains full control of its data and its patients' rights at all times. The Controller commits to:

- Supporting the Hospital in responding to any data subject request (access, rectification, erasure, restriction) within the legally required timeframes;
- Immediately informing the Hospital if any data subject rights request is received by the Controller that relates to the Hospital's data;
- Not acting on any data subject request without the Hospital's prior written authorisation.

6. Confidentiality and Security

The Controller shall maintain strict confidentiality over all Hospital data and shall implement technical and organisational measures (detailed in Page 3 of this package). Data access shall be limited strictly to the Controller personally and shall not be shared with any other individual. A separate Non-Disclosure Agreement is to be signed prior to any data access.

ARTICLE 30 GDPR — RECORD OF PROCESSING ACTIVITIES

Record of Processing Activities

ROPA — Maintained by Controller pursuant to Art. 30(1) GDPR

— PROCESSING ACTIVITY RECORD

This Record of Processing Activities is maintained by the Controller in accordance with Article 30(1) of Regulation (EU) 2016/679 (GDPR). It documents the single processing activity carried out under this pilot agreement.

FIELD	DETAIL
Controller	Maria Polychroniadou PhD Candidate & Founder, HealthLedgerAI Contact: info@healthledgerai.com
Processing Activity Name	HealthLedgerAI Billing Compliance Research Pilot
Purpose of Processing	AI-assisted billing compliance research (PhD doctoral programme). Validation of the HealthLedgerAI prototype against real hospital billing records to assess detection accuracy. Strictly non-commercial academic research purpose only.
Legal Basis	Art. 6(1)(f) Legitimate interest — scientific research Art. 9(3) Health data — academic research exemption Greek Law 4624/2019 · Cyprus Cap. 138
Categories of Data Subjects	Hospital patients (identifiable only by internal billing ID — no name, address, or national ID number accessed or processed)
Categories of Personal Data	Billing records: procedure codes, service dates, billed amounts, insurance codes, internal patient reference IDs. No direct patient identifiers (name, date of birth, national ID, contact details) are accessed or processed. Data classified as special category (health-related) per Art. 9 GDPR.
Recipients of Data	None. Data processed locally on the Controller's device only. No transmission to any third party, external server, or cloud platform.
Transfers to Third Countries	None. No international data transfers.
Retention Period	30 days post pilot-visit conclusion. All data deleted and deletion certified in writing upon expiry.
Technical & Organisational Measures	Local processing only · Encrypted storage (device full-disk encryption) · No cloud upload · Pseudonymised dataset used · Analysis outputs contain no direct identifiers · NDA signed prior to data access · Device password-protected
Data Processor(s)	The Hospital (name to be completed — see Page 1). Acts as the originating data holder; the Controller accesses data on-site under supervision.

FIELD	DETAIL
Date Record Created	June 2026
Last Updated	

— **LAWFULNESS ASSESSMENT NOTE**

The Controller has conducted a Legitimate Interest Assessment (LIA) confirming that: (a) the research purpose is genuine and documented within a doctoral programme; (b) the processing is necessary — no equally effective alternative using only synthetic data is available at the pilot stage; (c) the data subjects' interests are protected by pseudonymisation, strict local-only processing, 30-day deletion, and the absence of any commercial motive. The balancing test favours processing.

TECHNICAL & ORGANISATIONAL MEASURES

Technical & Organisational Measures

Security safeguards implemented for the HealthLedgerAI pilot — per Art. 32 GDPR

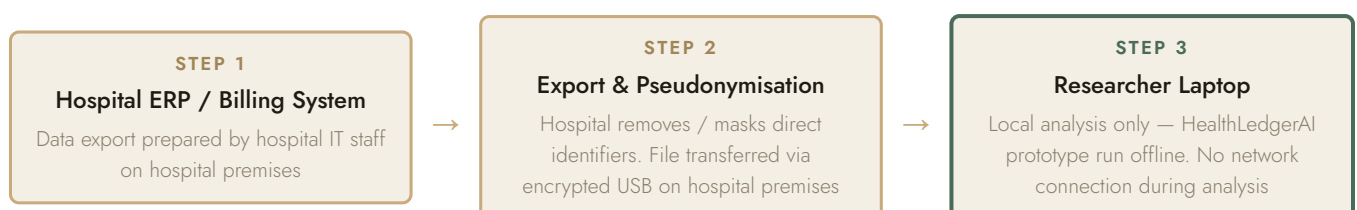
— SECURITY MEASURES CHECKLIST (TOMS)

The following technical and organisational measures are applied by the Controller for the duration of the pilot and for the 30-day retention period thereafter. The Hospital representative is invited to verify these measures during the pilot visit.

- ☐ **Local processing only.** All Hospital data is processed exclusively on the Controller's personal research laptop. No data leaves the device during or after analysis.
- ☐ **No cloud or external transmission.** Data is not uploaded to, stored in, or transmitted via any external server, cloud platform (including Google Drive, Dropbox, OneDrive, AWS, Azure, or equivalent), or third-party service of any kind.
- ☐ **Anonymisation / pseudonymisation applied before analysis.** The dataset provided by the Hospital is pseudonymised — direct patient identifiers (name, date of birth, national ID) are stripped or replaced with internal reference codes before the analysis is performed.
- ☐ **Analysis outputs contain no direct patient identifiers.** All reports and outputs generated by the HealthLedgerAI prototype reference only procedure codes, date ranges, and statistical aggregates. No output identifies a specific individual patient.
- ☐ **Encrypted storage at rest.** The Controller's device uses full-disk encryption. The data export file is additionally stored in an encrypted, password-protected container for the duration of the retention period.
- ☐ **Data deleted within 30 days of pilot visit.** All data — including the original export, working files, and any derivative files — is securely deleted within 30 calendar days of the pilot visit. Written deletion confirmation is provided to the Hospital.
- ☐ **Non-Disclosure Agreement signed separately before data access.** A Mutual NDA covering the Hospital's confidential and patient data is signed by both parties prior to any data export or access. A copy is retained by both parties.
- ☐ **Access restricted to the Controller only.** No other individual — including research supervisors, colleagues, or collaborators — accesses the Hospital's data. The Controller is the sole person processing the data.
- ☐ **Device physically secured.** The researcher's device is password-protected, kept in the researcher's physical possession at all times during the pilot, and not left unattended in a publicly accessible space.

— DATA FLOW DESCRIPTION

The following diagram illustrates the complete data lifecycle from export to deletion. At no stage does data leave the Hospital premises in unencrypted form or travel over a network connection.



STEP 4

Anonymised Output

Aggregate compliance report (no patient IDs) shared with hospital as feedback



STEP 5 · ≤30 DAYS

Secure Deletion

All source data, working files, and exports securely deleted.
Written confirmation issued.

Data minimisation. The Controller requests only the minimum data fields necessary to validate the prototype's billing-compliance detection. The Hospital is encouraged to provide an extract rather than a full billing database, covering only the period and record types required for the pilot (to be agreed in writing before the visit).

EXECUTION & SIGNATURE BLOCK

Agreement Signatures

Both parties confirm acceptance of the terms set out in this GDPR Pilot Documentation Package

By signing below, both parties confirm that they have read, understood, and agree to be bound by all terms set out in this Data Processing Agreement (Pages 1–4), including the Record of Processing Activities (ROPA) and the Technical & Organisational Measures (TOMs). This Agreement shall be effective from the date of the later signature below.

SIGNATURES

Maria Polychroniadou

Controller / Data Controller · HealthLedgerAI

SIGNATURE

FULL NAME (PRINTED)

ROLE / TITLE

DATE (DD / MM / YYYY)

Organisation	HealthLedgerAI
Capacity	PhD Researcher & Founder
Contact	info@healthledgerai.com

Hospital Representative

Data Controller · Authorised Signatory

SIGNATURE

FULL NAME (PRINTED)

ROLE / TITLE

DATE (DD / MM / YYYY)

OFFICIAL STAMP OF THE HOSPITAL

HOSPITAL DETAILS (TO BE COMPLETED BY HOSPITAL REPRESENTATIVE)

HOSPITAL / ORGANISATION FULL LEGAL NAME

DATA PROTECTION OFFICER (IF APPLICABLE)

REGISTERED ADDRESS

DPO CONTACT EMAIL / PHONE

This agreement is governed by EU Regulation 2016/679 (GDPR), the Greek Law 4624/2019 (ΔΠΑ — Νόμος για την Προστασία Δεδομένων Προσωπικού Χαρακτήρα), and the Cyprus Commissioner for Personal Data Protection Act Cap. 138.

This document forms part of the doctoral research record. A copy will be retained by both parties. Both parties are advised to have this document reviewed by their respective legal counsel or Data Protection Officer before signing.

Questions regarding this agreement: info@healthledgerai.com · healthledgerai.com